Web Application Security Assessment Report

1. Executive Summary

This report presents the results of a security assessment conducted on a deliberately vulnerable web application (DVWA). The objective was to identify and validate common web vulnerabilities, specifically SQL Injection (SQLi) and Cross-Site Scripting (XSS), using both manual testing techniques and interception via Burp Suite. The findings confirm that the application is vulnerable to critical attacks that could allow unauthorized data access and execution of malicious scripts in a real-world scenario.

2. Scope of Testing

The assessment was conducted in a controlled lab environment with the following constraints:

1. Target: DVWA running on local network
2. Security Level: Low (to simulate vulnerable configuration)
3. Testing limited to XSS and SQL Injection modules
4. No impact on production systems

3. Target Information

Application	DVWA
URL	http://172.20.10.10/dvwa
Security Level	Low
Database	MySQL

4. Methodology

The following methodology was used during testing:

1. Intercept HTTP traffic using Burp Suite proxy
2. Analyze request parameters and identify input points
3. Inject malicious payloads into parameters
4. Observe server responses and application behavior
5. Confirm exploitation through visible impact (data retrieval / script execution)

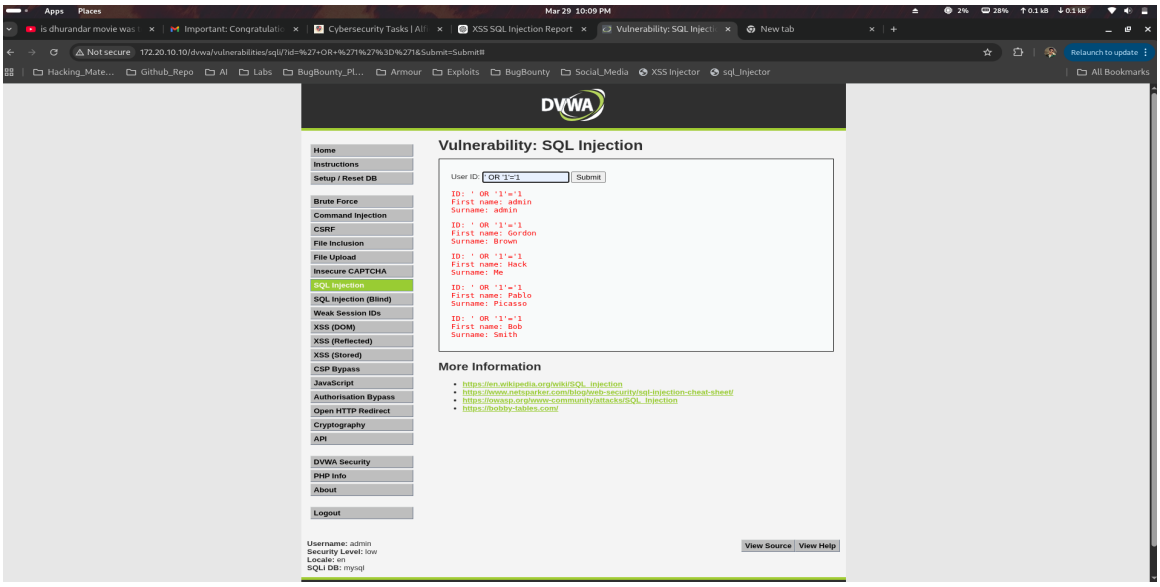
5. SQL Injection Vulnerability

SQL Injection occurs when user input is not properly sanitized before being used in SQL queries. This allows attackers to manipulate backend queries and access unauthorized data.

Payload Used: ' OR '1'='1

This payload forces the SQL condition to always evaluate as TRUE, resulting in retrieval of all records from the database.

Impact: The application returned multiple user records, demonstrating that authentication or data filtering mechanisms can be bypassed.



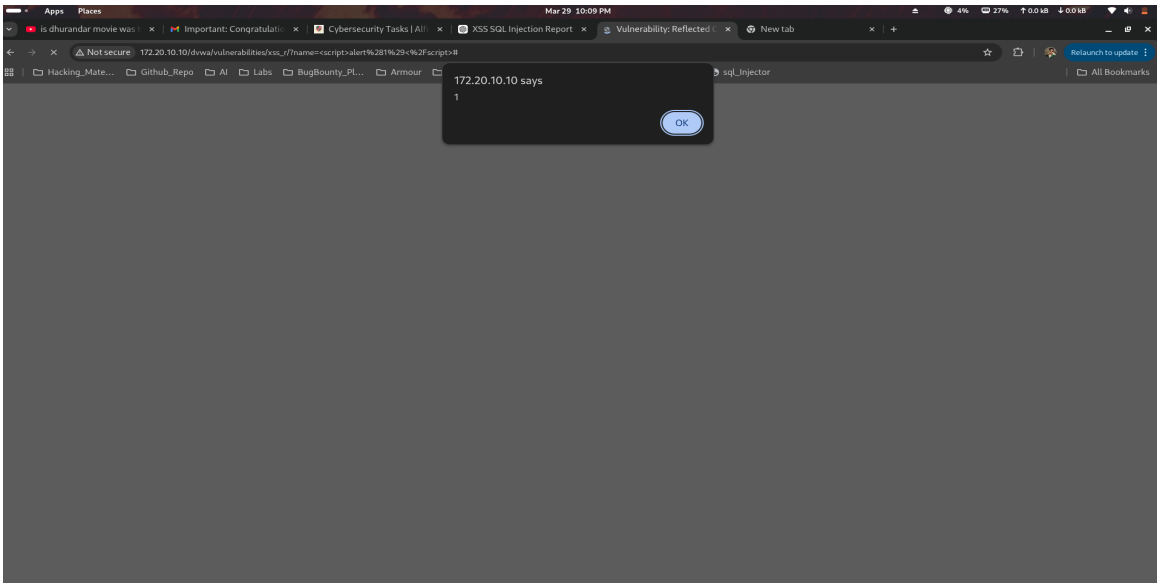
6. Cross-Site Scripting (XSS)

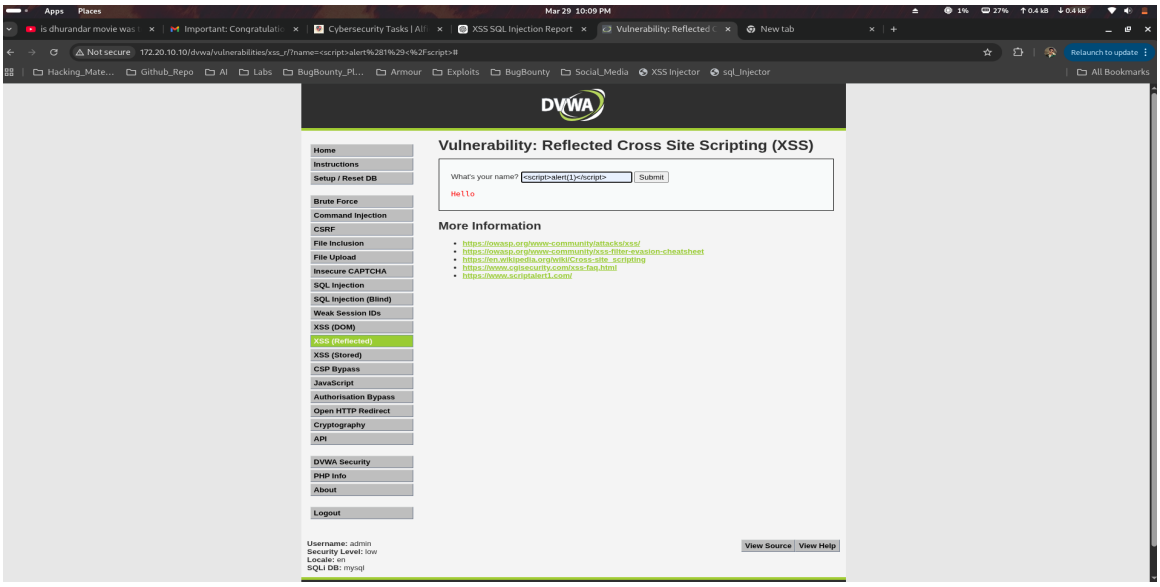
Cross-Site Scripting is a vulnerability that allows attackers to inject malicious scripts into web pages viewed by other users.

Payload Used: alert(1)

The payload was reflected in the HTTP response and executed by the browser, confirming lack of output encoding.

Impact: An attacker could execute arbitrary JavaScript, leading to session hijacking, phishing, or data theft.





7. Burp Suite Analysis

Burp Suite was used to intercept and manipulate HTTP requests. Requests were sent to the Repeater module to test different payloads and analyze responses in detail. This allowed precise control over input parameters and validation of vulnerabilities.

8. Mitigation Recommendations

1. Use parameterized queries to prevent SQL Injection
2. Validate and sanitize all user inputs
3. Implement output encoding to mitigate XSS
4. Deploy Content Security Policy (CSP)
5. Conduct regular security assessments and code reviews

9. Conclusion

The assessment identified critical vulnerabilities that could severely impact application security in a real-world deployment. Immediate remediation is strongly recommended to ensure data protection and system integrity.